BÖLÜM 7: GÜVENLIK VE SIFIR GÜVEN — KRALLIĞI SAVUNMAK

💣 9 dk • DERS 25

Parça 25: Sıfır Güven Mimarisi (Zero Trust): Asla Güvenme, Daima Doğrula

Kurumsal VPN çevrelerinin neden öldüğü ve mikroservislerin karşılıklı TLS (mTLS) ile nasıl güvenceye alınacağı.

> 🔥 **SAHADAN YAŞANMIŞ KRİZ HİKAYESİ**
>
> 2013 yılında perakende devi Target, tarihin en büyük veri ihlallerinden birini yaşadı. Saldırganlar ana ödeme sistemine doğrudan sızmadı; Target'ın soğutma sistemlerini uzaktan izleyen üçüncü parti bir havalandırma (HVAC) taşeronunun VPN giriş bilgilerini çaldılar. VPN'in içine girdiklerinde ağın devasa, dümdüz bir salon olduğunu gördüler: İçeride hiçbir iç güvenlik duvarı veya mikroservis kimlik kontrolü yoktu! Saldırganlar havalandırma sunucusundan doğrudan mağaza kasalarının pos cihazlarına atladılar ve 40 milyon kredi kartını kopyaladılar. Target 200 milyon dolardan fazla tazminat ödedi ve CEO istifa etmek zorunda kaldı.

Zihniyet Dönüşümü: Kod Yazarlığından Mimarlığa

Geleneksel 'Kale ve Hendek' modeli (güvenlik duvarının içindeki her şeye güven, dışındakilere güvenme) artık çökmüştür. Saldırgan bir oltalama e-postası veya bir taşeron şifresiyle iç ağa sızdığı anda tüm veritabanlarınız savunmasız kalır. **Sıfır Güven (Zero Trust) Mimarisi** şu üç ilkeyle çalışır: 1) Açıkça doğrula, 2) En az yetkiyi ver, 3) İhlal edildiğini varsay. İç ağdaki her bir servis, yanındaki diğer servise sanki açık internetteymiş gibi şüpheyle yaklaşmalıdır.

Temel Mimari İlkeler ve Zihinsel Modeller

Yazılım Mimarları İçin Sıfır Güven İlkeleri

- **Çevre Değil, Kimlik:** IP adresleri güven sağlamaz. Her istek kriptografik olarak imzalanmış kimlik token'ları (SPIFFE ID, JWT, OAuth) taşımalıdır.
- **Karşılıklı TLS (mTLS):** Standart TLS'de sadece istemci sunucunun sertifikasını doğrular. mTLS'de ise SUNUCU DA İSTEMCİYİ doğrular. İki taraf da kimliğini kanıtlar ve ağdaki tüm trafik şifrelenir. Servis mesh (Istio, Linkerd) veya Envoy yan araçlarıyla uygulama koduna dokunmadan kurulur.

Mikro Segmentasyon ve En Az Yetki İlkesi

Ön yüz web servisi doğrudan müşteri ödeme veritabanına ağ seviyesinde fiziksel olarak bağlanamamalıdır. Yalnızca kimliği doğrulanmış bir mTLS kanalı üzerinden Ödeme API'siyle konuşabilir.

Kaçınılması Gereken Anti-Pattern'ler ve Tuzaklar

- **Düz İç Ağ Rehaveti:** 'Burası bizim güvenli AWS VPC'miz, kendi kodumuza da mı güvenmeyeceğiz?' diyerek servisler arasındaki kimlik doğrulamasını kapatmak.
- **Statik IP Beyaz Listesi:** Konteynerlerin sürekli yeniden başlayıp IP değiştirdiği bulut ortamlarında statik IP listeleriyle güvenlik sağlamaya çalışmak.
- **Aşırı Yetkili Servis Hesabı:** Basit bir e-posta bildirim servisine 'yapılandırması kolay olsun' diye AWS `AdministratorAccess` yetkisi vermek.

🎯 MİMARIN EYLEM PLANI: BU HAFTAKİ SOMUT ADIMLAR

- **1. Adım:** İç servis ağını denetle: Kümedeki rastgele bir konteyner doğrudan canlı veritabanına şifresiz TCP sorgusu atabiliyor mu?
- **2. Adım:** Mikroservisler arasına Envoy veya hafif bir servis mesh ile mTLS kur.
- **3. Adım:** Her servisin bulut IAM rollerini denetle; tüm joker (*) izinleri kaldırıp en az yetki kuralını uygula.

Mimari Çıkarımlar ve Hile Tablosu

- Saldırganın zaten iç ağınızda olduğunu varsayın; savunmanızı buna göre tasarlayın.
- IP adresleri kimlik değildir; kriptografik sertifikalar ve token'lar kimliktir.
- Mikro segmentasyon ve mTLS ile hasar yarıçapını olabildiğince daraltın.

🎙️ UDEMY & NOTEBOOKLM TARTIŞMA VE ÖDEV SORUSU

Ders Değerlendirmesi ve Ödev: Kötü niyetli biri şu an ön yüz sunucularınızdan birine shell erişimi sağlasa, şifresiz olarak başka hangi veritabanlarına veya iç servislere erişebilir?